2026 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드

Chapter 08 — DBMS 보안 취약점 분석 및 평가

Oracle DB, MSSQL, MySQL, Altibase, Tibero, PostgreSQL, Cubrid 등 주요 DBMS에 대한 계정·접근·옵션·패치 관리 항목별 점검 방법과 조치 사례를 상세히 안내합니다.

DBMS 취약점 점검 항목 전체 구성

총 26개 항목(D-01 ~ D-26)으로 구성되며, 4개 영역으로 분류됩니다.

1. 계정 관리

D-01 ~ D-09 · 9개 항목

기본 계정 변경, 불필요 계정 제거, 비밀번호 정책, 관리자 권한 통제 등

2. 접근 관리

D-10 ~ D-16 · 7개 항목

원격 접속 제한, 시스템 테이블 접근 통제, 리스너 보안, 파일 권한 설정 등

3. 옵션 관리

D-17 ~ D-24 · 8개 항목

Audit Table 접근 제한, Public Role 제한, OS 인증 비활성화, xp_cmdshell 제한 등

4. 패치 관리

D-25 ~ D-26 · 2개 항목

주기적 보안 패치 적용, 감사 기록 정책 설정

계정 관리 점검 항목 (D-01 ~ D-09)

점검 항목	중요도	코드	비고
기본 계정의 비밀번호·정책 변경 사용	상	D-01	초기 비밀번호 대입 공격 차단
불필요 계정 제거 또는 잠금 설정	상	D-02	SCOTT, ADAMS 등 Demo 계정 포함
비밀번호 사용기간 및 복잡도 설정	상	D-03	기관 정책 준수
DB 관리자 권한 최소 계정에만 허용	상	D-04	최소 권한 원칙
비밀번호 재사용 제약 설정	중	D-05	
DB 사용자 계정 개별 부여	중	D-06	공유 계정 금지
root 권한으로 서비스 구동 제한	중	D-07	
안전한 암호화 알고리즘 사용	상	D-08	
로그인 실패 시 잠금 정책 설정	중	D-09	일정 횟수 초과 시 잠금

D-01 · 기본 계정 비밀번호 및 정책 변경

중요도: 상

D-01

점검 목적 및 보안 위험

DBMS 기본 계정(예: **sa**, **sys**, **root**)의 초기 비밀번호를 변경하지 않으면, 비인가자가 인터넷을 통해 초기 비밀번호를 획득하여 DB에 접근하고 정보를 유출할 수 있습니다.

양호: 초기 비밀번호 변경 또는 잠금 설정
취약: 초기 비밀번호 미변경 또는 잠금 미설정

비밀번호 관리 기준

- 영문 대·소문자, 숫자, 특수문자 중 **2종류 이상 조합 시 최소 10자리** 이상
- **3종류 이상 조합 시 최소 8자리** 이상
- 계정명과 상이한 비밀번호 사용
- 시스템마다 상이한 비밀번호 사용
- 주기적으로 비밀번호 변경

D-01 · 주요 DBMS별 기본 계정 비밀번호 변경 방법

1

Oracle DB

```
-- 비밀번호 변경
ALTER USER <기본 계정명> IDENTIFIED BY <신규 비밀번호>;
-- 계정 잠금
ALTER USER <기본 계정명> ACCOUNT LOCK;
```

2

MSSQL

```
ALTER LOGIN sa WITH PASSWORD = '신규 비밀번호';
```

3

MySQL 5.7 / 8.0

```
-- 5.7
UPDATE user SET authentication_string = PASSWORD('신규')
WHERE User = 'root';
-- 8.0
ALTER USER 'root'@'localhost' IDENTIFIED BY '신규 비밀번호';
FLUSH PRIVILEGES;
```

4

Altibase / Tibero / PostgreSQL / Cubrid

```
-- Altibase/Tibero
ALTER USER sys IDENTIFIED BY [신규 비밀번호];
-- PostgreSQL
ALTER USER postgres WITH PASSWORD '신규 비밀번호';
-- Cubrid
ALTER USER "계정명" PASSWORD '신규 비밀번호';
```

Oracle DB 주요 기본 계정 목록 (D-01 참고)

아래 계정들은 Oracle DB 설치 시 기본 생성되는 계정으로, 초기 비밀번호 변경 또는 잠금 조치가 필요합니다.

계정(User)	기본 비밀번호	계정(User)	기본 비밀번호
scott	tiger / tigger	system	manager
dbsnmp	dbsnmp	sys	change_on_install
tracesvr	trace	outln	outln
ordplugins	ordplugins	ordsys	ordsys
ctxsys	ctxsys	mdsys	mdsys
adams	wood	blake	papr
clark	clth	jones	steel
lbacsys	lbacsys	—	—

⚠ 위 계정들의 초기 비밀번호가 변경되지 않은 경우 즉시 변경하거나 잠금 처리해야 합니다.

D-02 · 불필요 계정 제거 및 잠금 설정

중요도: 상

D-02

점검 목적 및 보안 위험

SCOTT, PM, ADAMS, CLARK 등 **Demonstration 계정** 및 퇴사·직무 변경으로 더 이상 사용하지 않는 계정이 존재할 경우, 비인가자가 해당 계정으로 DB에 접근하여 데이터를 열람·삭제·수정할 위험이 있습니다.

양호: 불필요한 계정이 없는 경우
취약: 인가되지 않은 계정, 퇴직자 계정, 테스트 계정 등이 존재하는 경우

조치 방법 요약

- 계정별 용도 파악 후 불필요한 계정 삭제
- 삭제 시 해당 계정의 Object 및 Demonstration 계정 사용 불가

Tibero 정적 뷰 참고

- `ALL_USERS`: 모든 사용자 기본 정보
- `DBA_USERS`: 모든 사용자 상세 정보
- `USER_USERS`: 현재 사용자 정보

D-02 · DBMS별 불필요 계정 확인 및 삭제 명령어

Oracle DB

```
-- 계정 삭제
DROP USER [삭제할 계정];
```

MSSQL

```
EXEC sp_droplogin '삭제할 계정';
```

MySQL

```
DROP USER '삭제할 계정'@'호스트명 or IP';
FLUSH PRIVILEGES;
```

Altibase / Tibero

```
-- 사용자 확인
SELECT * FROM system._sys_users;
-- 계정 삭제
DROP USER user_name CASCADE;
```

PostgreSQL

```
-- 사용자 확인
\du
-- 계정 삭제
DROP ROLE '삭제할 계정';
```

Cubrid

```
-- 계정 목록 확인
SELECT name, password FROM db_user;
-- 계정 삭제
DROP USER [삭제할 계정];
```

접근·옵션·패치 관리 점검 항목 (D-10 ~ D-26)

2. 접근 관리 (D-10 ~ D-16)

점검 항목	중요도	코드
원격 DB 서버 접속 제한	상	D-10
시스템 테이블 비인가 접근 차단	상	D-11
안전한 리스너 비밀번호 설정	상	D-12
불필요 ODBC/OLE-DB 제거	중	D-13
주요 설정·비밀번호 파일 접근 권한	중	D-14
리스너 로그·trace 파일 변경 제한	하	D-15
Windows 인증 모드 사용	하	D-16

3. 옵션 관리 (D-17 ~ D-24)

점검 항목	중요도	코드
Audit Table 접근 DBA 계정으로 제한	하	D-17
DBA Role Public 설정 금지	상	D-18
OS_ROLES 등 FALSE 설정	상	D-19
비인가 Object owner 제한	하	D-20
비인가 GRANT OPTION 제한	중	D-21
DB 자원 제한 기능 TRUE 설정	하	D-22
xp_cmdshell 사용 제한	상	D-23
Registry Procedure 권한 제한	상	D-24

4. 패치 관리 (D-25 ~ D-26)

주기적 보안 패치 및 벤더 권고 적용	상	D-25
감사 기록 정책 적합 설정	상	D-26

DBMS 보안 점검 핵심 요약

계정 관리 (D-01~D-09)

기본 계정 비밀번호 즉시 변경, 불필요 계정 삭제, 관리자 권한 최소화, 로그인 실패 잠금 정책 적용

접근 관리 (D-10~D-16)

원격 접속 제한, 시스템 테이블 보호, 리스너 비밀번호 설정, 주요 파일 접근 권한 강화

옵션 관리 (D-17~D-24)

Public Role 제한, OS 인증 비활성화, xp_cmdshell 및 Registry Procedure 권한 제한

패치 관리 (D-25~D-26)

주기적 보안 패치 적용 및 벤더 권고 사항 준수, 접근·변경·삭제 감사 기록 정책 설정

본 가이드는 Oracle DB, MSSQL, MySQL, Altibase, Tibero, PostgreSQL, Cubrid 등 주요 DBMS에 공통 적용되며, 각 항목의 중요도(상·중·하)에 따라 우선순위를 두어 조치하는 것을 권장합니다.